

시스템 흐름과 아키텍처

하드웨어에 묶인 암호 서명, 페어링 프로토콜, 그리고 다층 수신자 방어가 어떻게
결합되어 SIM-swap 기반 보이스피싱을 CHON 사용자에게 무력화시키는가.

문서

시스템 아키텍처 및 런타임 흐름

범위

Mobile · Main backend · VP API ·
Push

상태

dev / stg 브랜치의 출시 코드 반영

목차

01	한 문단으로 — CHON이 하는 일
02	네 가지 컴포넌트
03	신뢰 체인
04	신원 계층 — 무엇이 누구를 증명하는가
05	회원가입 → 첫 세션
06	4시간 하트비트
07	상호인증 — 페어링 흐름
08	PRECALL — 통화별 서명
09	LIVENESS_UPDATE — iPhone 시스템 통화 대비책
10	수신자 화면 표시 — 세 가지 상태
11	음성 안내 (Android)
12	전체 공격 시나리오
13	저장 데이터 — 전체 그림
14	현황 요약
15	공격자에게 열려 있는 두 개의 문
16	결론
A	용어집

01 한 문단으로

CHON은 인증된 가족 구성원 간의 모든 통화에 위조 불가능한 두 번째 신원 신호를 추가합니다. 이 신호는 Apple Secure Enclave 또는 Android StrongBox 내부에서 생성된 하드웨어 결속 암호 서명이며, 셀룰러 벨소리가 울리기 약 3초 전에 수신자에게 전달됩니다.

수신자의 단말은 이 서명을 사용하여 다음 세 가지 판정 중 하나를 선택합니다:

● VERIFIED 녹색 배너 하드웨어 검증 완료, 가족 페어링이 확인된 통화입니다. "안전합니다."	● UNKNOWN 노란색 배너 최근 인증이 갱신되지 않음 — 주의가 필요합니다. "주의하세요."	● SIM-SWAP 빨간색 배너 인증된 페어링이지만 칩 없이 걸려온 통화 — 의심됩니다. "보이스피싱 의심 전화입니다."
--	---	---

가족이 한 번 페어링되면 이후 모든 과정은 사용자 입력 없이 자동으로 동작합니다. 방어는 다층 구조입니다. 어떤 신호가 발생할 수 없는 상황 — 예를 들어 iOS 시스템 다이얼러는 통화별 PRECALL 을 발행할 수 없는데 — 이때는 대비책 신호가 대신 작동합니다. LIVENESS 팬아웃이 Android 수신자의 캐시를 유지시켜 iPhone 발신자도 통화별 서명 없이 녹색을 받을 수 있게 해줍니다.

핵심 아이디어

이것은 전화번호 기반 방어가 아닙니다. SIM-swap, 번호 스푸핑, Caller-ID 주입 — 어떤 것도 CHON을 무력화할 수 없습니다. 왜냐하면 **CHON은 번호가 아니라 칩을 신뢰하기 때문입니다.**

02 네 가지 컴포넌트

시스템은 네 개의 협력 컴포넌트로 구성되며, `ap-northeast-2` 리전의 AWS Application Load Balancer를 통해 HTTPS로 통신합니다.

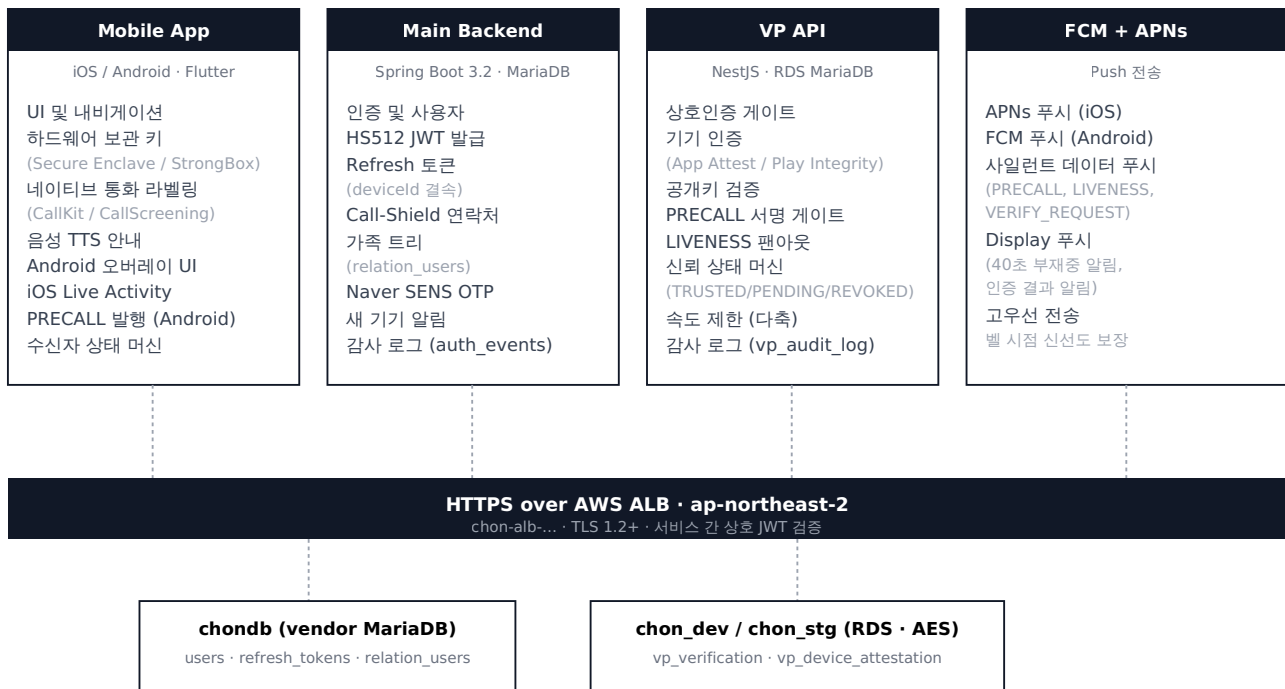


그림 2.1 — 네 컴포넌트는 AWS ALB를 통해 단일 네트워크 평면을 공유하며, Main Backend와 VP API는 분리되고 격리된 데이터베이스를 갖습니다.

인증 경계

Main Backend가 HS512 JWT를 발급하며, VP API는 동일한 Secrets Manager 키로 이를 검증합니다. JWT는 `sub`, `uname`, `phone` claim을 담고 있습니다. VP API는 첫 요청 시 이 claim들로부터 자체 `users` 테이블에 레코드를 자동 생성하여, 두 서비스가 데이터베이스를 공유하지 않고도 신원을 공유할 수 있게 합니다.

03 신뢰 체인

모든 통화별 서명은 결국 단 하나의 물리적 하드웨어로 거슬러 올라갑니다. 단말의 보안 요소(secure element) 안에서 생성되어 그 안에 보관되는 비공개 키입니다. 서버는 이에 대응하는 공개 키와, 해당 단말의 위치를 기술하는 상태값만 보관합니다.

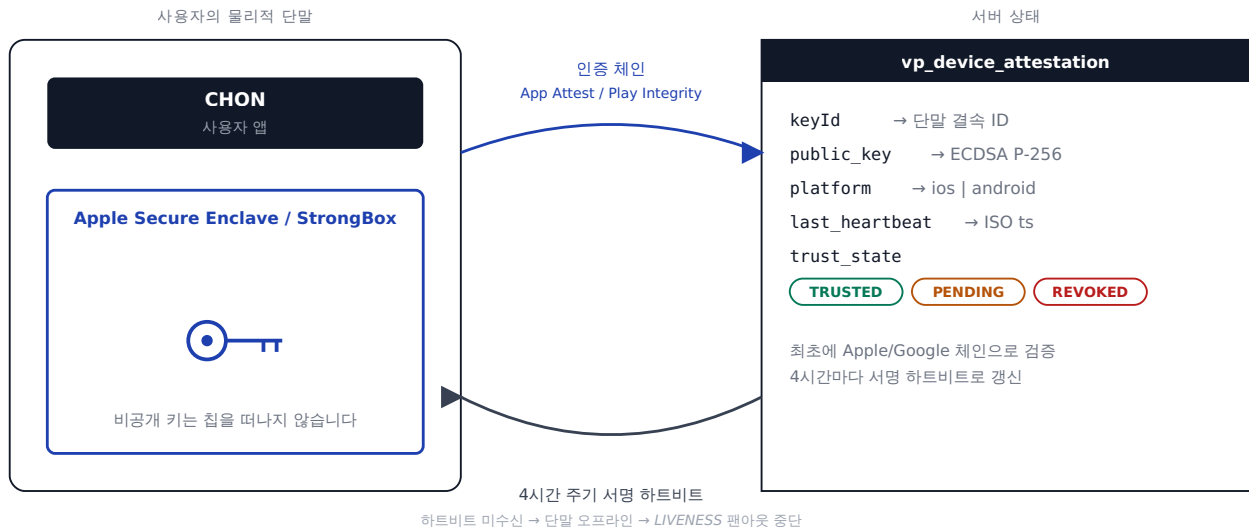


그림 3.1 — 단말의 보안 요소가 보유한 비공개 키는 통신 회선을 절대 건너지 않으며, 서버는 공개 키와 단말의 신뢰 상태만 보관합니다.

보장

실제 칩을 가진 단말만이 저장된 공개 키와 검증되는 서명을 생성할 수 있습니다. SIM-swap, 비밀번호 탈취, 서버 침해도 이 서명을 위조할 수 없습니다.

최초 설치 vs. 재설치 vs. 새 단말

최초 설치는 정상 단말에서 Apple/Google 체인 검증 후 `trust_state = TRUSTED` 를 받습니다. **재설치**는 동일 물리 단말(deviceId가 이미 알려진)에서 `TRUSTED` 를 유지합니다. **기존 계정의 새 단말**은 `PENDING` 으로 시작하며, 사용자가 새 단말 알림 이메일과 푸시 알림을 처리할 때까지 그 상태를 유지합니다 — 이는 다른 단말에서의 자격 증명 도용 시도를 차단합니다.

04 신원 계층 — 무엇이 누구를 증명하는가

CHON의 보호력은 두 개의 특정 계층 — 단말 키와 페어링 — 을 함께 묶는 데서 나옵니다. 발신자가 칩을 가지고 있음을 증명하고 동시에 수신자가 그를 신뢰하기로 동의했음을 모두 만족해야 합니다. 어느 한쪽만으로는 충분하지 않습니다.

1	전화번호 셀룰러 MSISDN	저장 위치: 통신사
2	계정 자격 이메일 + 전화 + 비밀번호	Main backend · users
3	세션 HS512 JWT + refresh 토큰	Main backend · refresh_tokens
4	단말 하드웨어 키 + 인증	VP API · vp_device_attestation
5	페어링 상호인증	VP API · vp_verification
6	가족 트리 사용자가 추가한 관계	Main backend · relation_users

왜 4계층과 5계층인가

1~3계층만으로는 위조가 가능합니다. 4계층은 Apple/Google 인증을 통해 신원을 물리 하드웨어와 묶어주며, 칩은 공격자가 획득하기 가장 어려운 단일 요소입니다. 5계층은 수신자의 hold-to-confirm 실제 확인을 요구하므로 우발적 승인이 통한 권한을 부여하지 않습니다. 두 계층이 결합되어 누가 누구에게 PRECALL이나 LIVENESS를 발생시킬 수 있는지를 정의합니다.

05 회원가입 → 첫 세션

최초 설치 시 앱은 사용자 계정, 세션, 푸시 토큰, 그리고 하드웨어 결속 키를 단일 온보딩 흐름 안에서 모두 설정합니다.

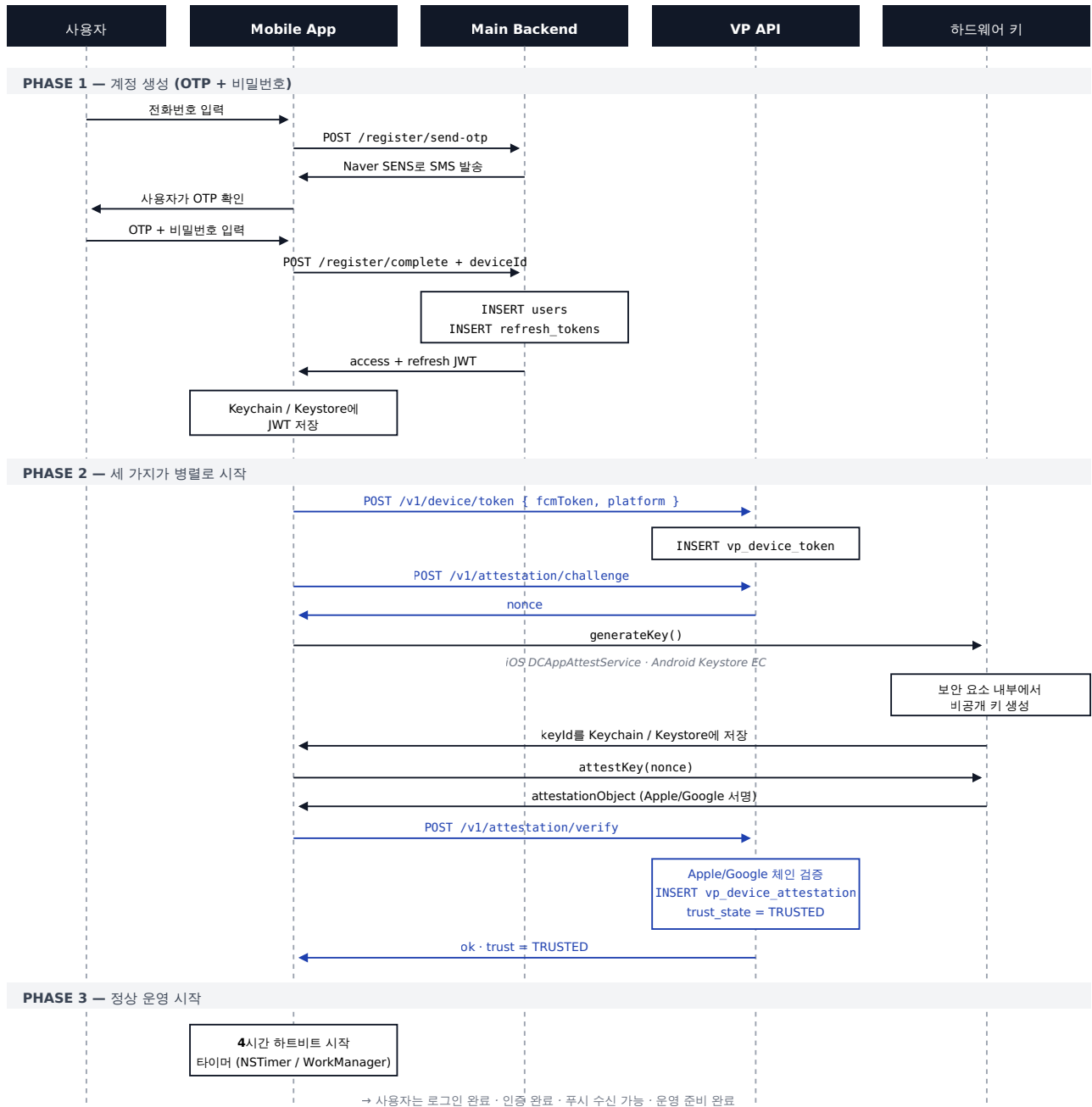


그림 5.1 — 최초 설치 온보딩. 계정 생성, 푸시 등록, 하드웨어 키 인증이 단일 흐름 안에서 완료됩니다.

06 4시간 하트비트

인증이 완료되면, 단말은 4시간마다 자신이 살아있고 — 그리고 여전히 하드웨어 키를 소유하고 있음을 — 증명합니다. 서명이 그 증거이며, 그 무엇도 이를 대체할 수 없습니다.

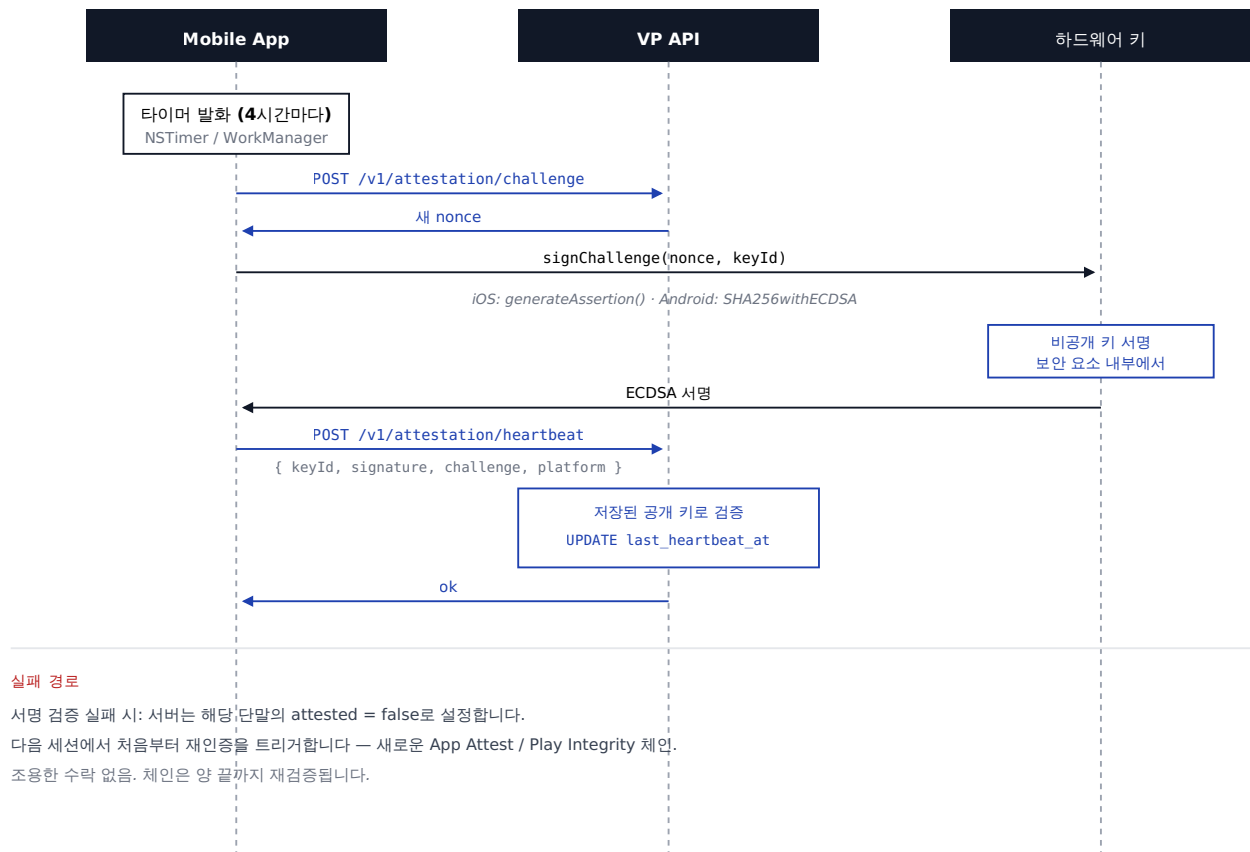


그림 6.1 — 하트비트는 서버가 발급한 nonce에 대해 새로 서명된 assertion입니다. 하드웨어 키는 통신 회선을 절대 건너지 않습니다.

핵심 불변

하드웨어 비공개 키는 보안 요소를 절대 떠나지 않습니다. 서버가 보는 것은 오직 공개 키(인증 시 한 번)와 서명들(하트비트마다, PRECALL마다, 재인증마다)입니다. 서버가 완전히 침해되더라도 유효한 서명을 위조할 수 없습니다.

07 상호인증 — 페어링 흐름

두 사용자가 녹색 배너 통화를 주고받기 전에, 그들은 페어링되기로 합의해야 합니다. 페어링 흐름은 양방향이며, 응답자 측에서 hold-to-confirm을 요구하고, 서버에서 다축 속도 제한과 관계 검사로 게이팅됩니다.

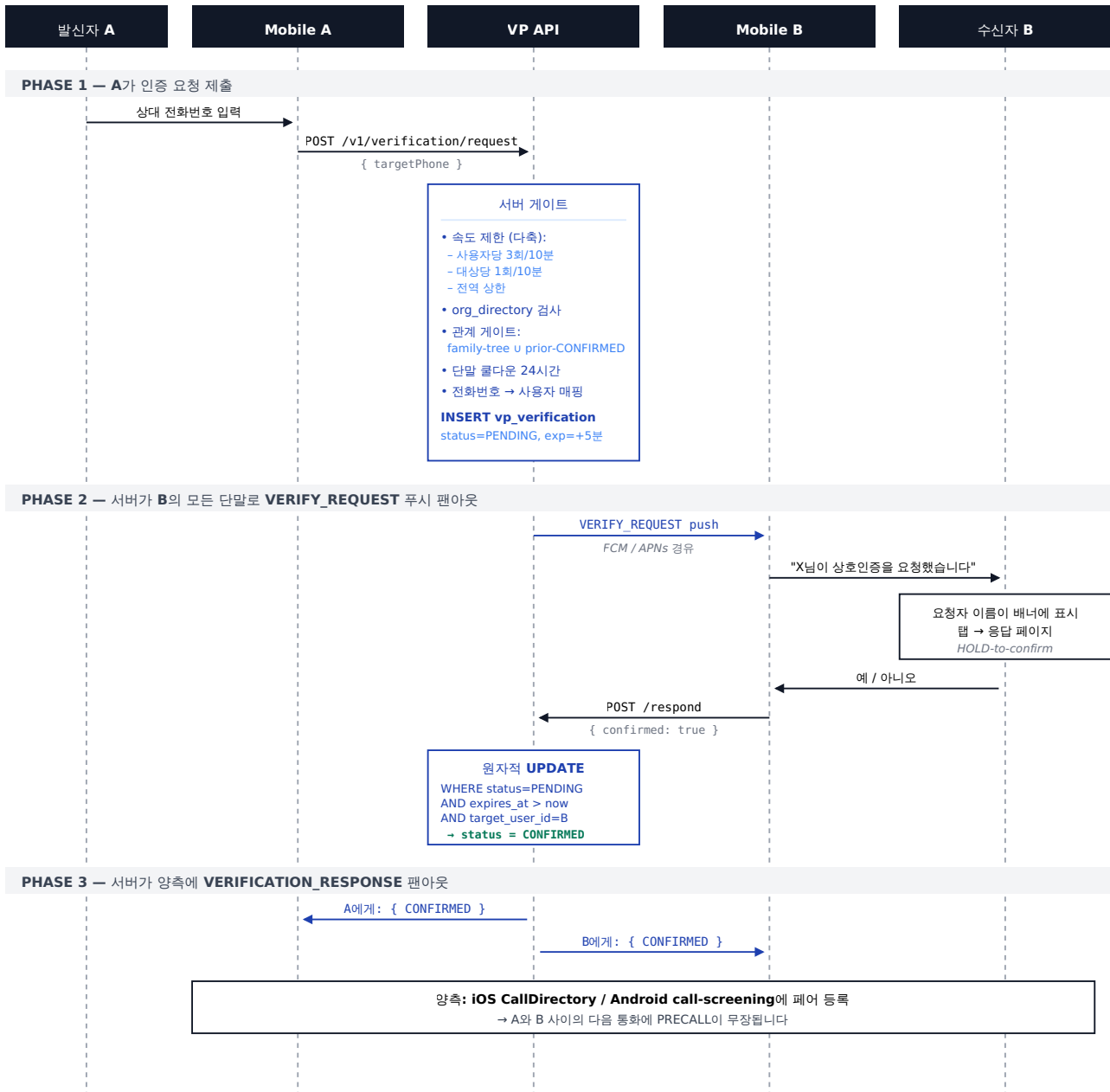


그림 7.1 — 페어링은 다축 속도 제한, 관계 검사, 그리고 5분 PENDING TTL과 원자적 응답으로 게이팅됩니다. Hold-to-confirm이 우발적 승인을 방지합니다.

왜 HOLD-TO-CONFIRM인가

푸시 배너의 단순 탭은 위조나 우발적 발화가 너무 쉽습니다. 응답 페이지는 사용자가 확인 버튼을 누른 채로 유지하도록 요구합니다 — 요청자의 실제 계정 이름을 읽고 결정할 충분한 시간을 갖도록 말입니다. 보이스피싱은 수신자가 낯선 사람을 승인할 때만 작동합니다. 이 프롬프트는 그 낯선 사람을 가시화시킵니다.

08 PRECALL — 통화별 서명

이것이 실시간 방어의 핵심입니다. 페어링된 CHON 사용자 간의 모든 통화는 셀룰러 벨소리가 울리기 약 3초 전에 도착하는 하드웨어 서명 사일런트 푸시를 동반합니다. 이 푸시만이 수신자에게 녹색 배너를 띄울 수 있는 유일한 방법이며 — 서명만이 유효한 푸시를 만들어낼 수 있는 유일한 방법입니다.

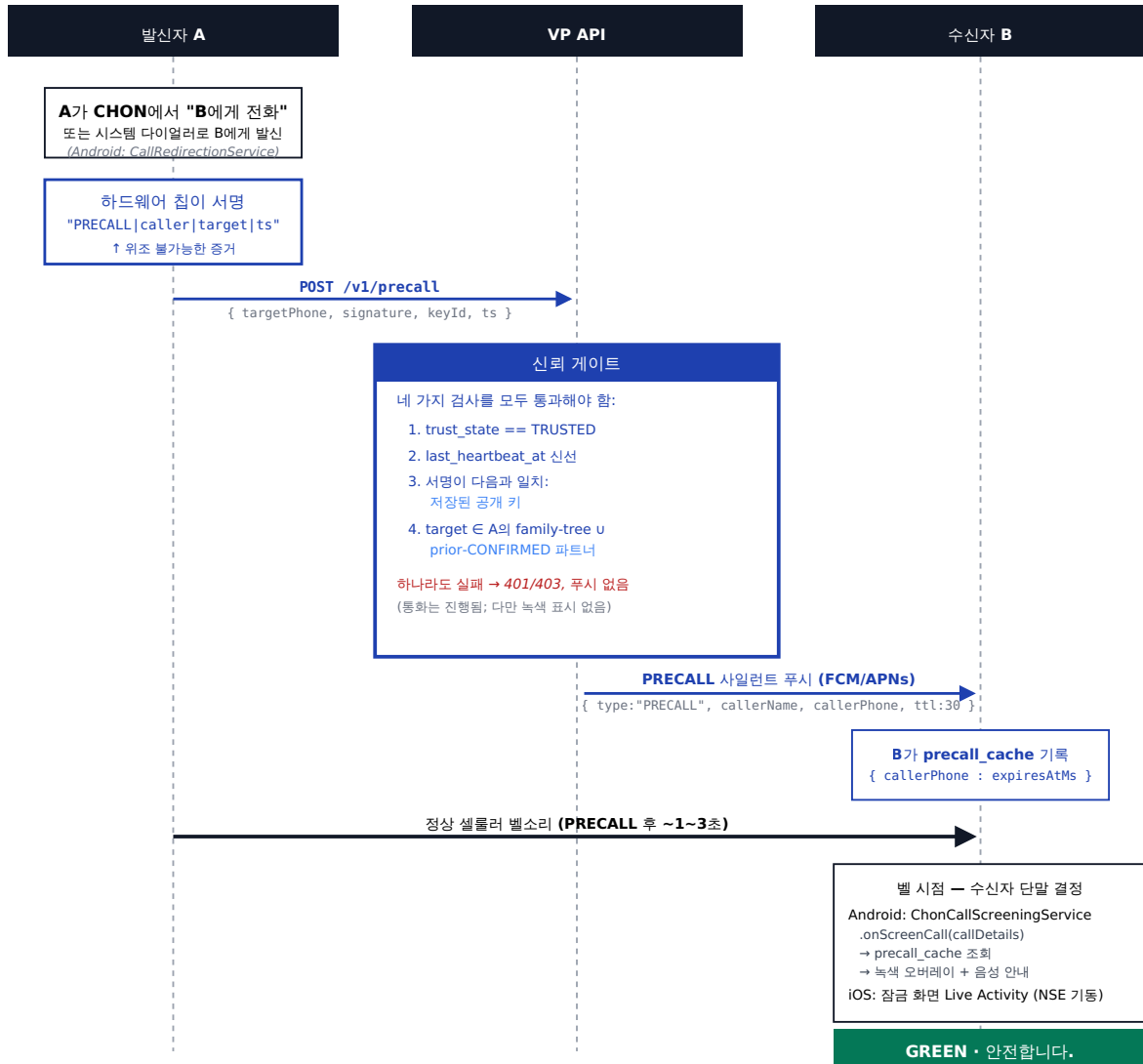


그림 8.1 — PRECALL 흐름. 칩이 서명하고, 서버가 검증·게이트팅하고, 수신자가 캐싱하고, 스크리닝 서비스가 벨 시점에 캐시를 읽습니다.

왜 이것이 가장 단단한 게이트인가

공격자는 Caller-ID 스푸핑, SIM 포팅, 비밀번호 도용, 심지어 서버 침해까지 — 그 어떤 것도 가능하지만 — 피해자의 잠금 해제된 실제 단말을 물리적으로 점유하지 않고는 유효한 PRECALL 서명을 만들어낼 수 없습니다. 칩이 바로 그 병목점입니다.

09 LIVENESS_UPDATE — iPhone 시스템 통화 대비책

iPhone은 사용자가 시스템 전화 앱에서 발신할 때 PRECALL을 발생시킬 수 없습니다 — Apple이 서드파티 앱에 CallRedirectionService에 해당하는 API를 제공하지 않기 때문입니다. 대비책 없이는 모든 iPhone 시스템 다이얼러 통화가 PRECALL 없이 도달하여 SIM-swap처럼 보일 것입니다. LIVENESS_UPDATE는 Android 수신자의 캐시를 따뜻하게 유지시켜 iPhone 발신자도 여전히 녹색을 받을 수 있도록 합니다.

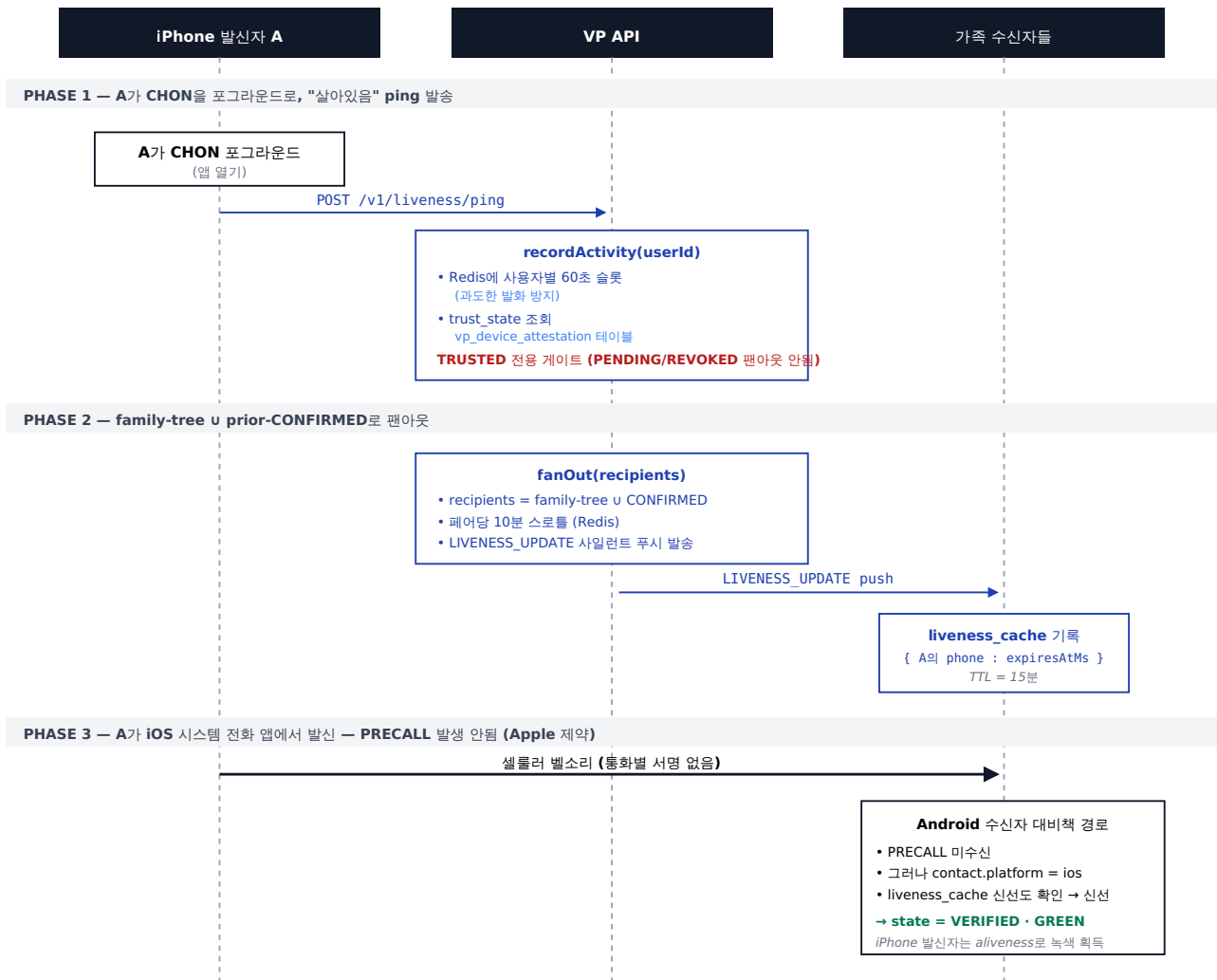


그림 9.1 — LIVENESS_UPDATE는 Apple의 CallRedirection 제약을 보완합니다. TRUSTED 전용 게이트는 대비책 경로에서도 SIM-swap 방어를 그대로 유지합니다.

왜 TRUST_STATE이지 하트비트 신선도가 아닌가

이 게이트의 이전 버전은 `last_heartbeat_at` 신선도에 의존했습니다. 스테이징에서 신규 설치 사용자는 인증 직후 `lastHeartbeat`이 null이라 팬아웃이 차단되는 것을 발견했습니다. `trust_state == TRUSTED`로 전환하여 그 갭을 메우면서도 SIM-swap 방어는 그대로 유지했습니다: PENDING 및 REVOKED 단말은 절대 팬아웃되지 않습니다.

10 수신자 화면 표시

수신자가 벨 시점에 실제로 보는 화면은 플랫폼별로 다릅니다. Android는 전체 화면 오버레이를 그리고 음성으로 판정을 들려줄 수 있는 반면, iOS에서는 Apple의 프레임워크가 허용하는 범위로 제한됩니다.

Android — 전체 화면 오버레이

● VERIFIED · GREEN

하드웨어 인증됨

PRECALL 신선, 또는 iOS 플랫폼 연락처 + LIVENESS 신선. 다이얼러 위에 전체 녹색 오버레이; 이름 표시.

"안전합니다. {name}에게서 온 인증된 전화입니다."

● UNKNOWN · YELLOW

주의

알려진 iOS 플랫폼 연락처이지만 PRECALL과 LIVENESS 신선도가 모두 없음. 노란색 오버레이; 이름 표시.

"주의하세요. {name} 번호이지만 실시간 인증이 확인되지 않았습니다."

● SIM-SWAP · RED

의심

알려진 Android 플랫폼 연락처 AND PRECALL 부재 — SIM은 가졌지만 칩이 없는 공격자의 정확한 시그니처. 이름을 숨김.

"주의하세요. 보이스피싱 의심 전화입니다. 받지 마세요."

SIM-SWAP의 결정적 신호

CHON Android 클라이언트는 인증된 연락처에게 발신할 때 항상 CallRedirectionService를 통해 PRECALL을 발생시킵니다. **인증된 Android 연락처에서 PRECALL 없이 들어오는 통화**는 정확히 SIM은 가졌지만 칩이 없는 공격자의 모습입니다. 이 상태에서는 공격자가 신뢰 표시를 악용하지 못하도록 이름을 숨깁니다.

iOS — Apple이 허용하는 것

표면	렌더링 내용
CallDirectory 라벨	통화 화면의 정적 라벨 — "✓ {name} · 인증된 가족". Apple의 API는 사전 컴파일된 목록만 지원하므로 통화별로 변경할 수 없습니다.
Live Activity Pro 모델	잠금 화면 + Dynamic Island에 PRECALL 윈도우 동안 30초 카운트다운과 함께 녹색 CHON 실드를 표시. 푸시 수신 시 NSE에서 시작. 비-Pro 모델에서는 Apple의 전체 화면 UI에 가려짐.
부재중 알림 후속	모든 PRECALL 후 40초가 지나면 서버가 표시 가능한 FCM 푸시를 발송: "{name}님이 안전 통화를 시도했어요". 앱 상태와 무관하게 도달하여 iOS의 일반 부재중 통화 항목을 대체합니다.

iOS는 Android보다 의도적으로 약합니다. Apple이 서드파티 앱에 통화 화면을 그리거나 벨 시점에 코드를 실행할 수 있게 허용하지 않기 때문입니다. 위의 세 표면을 통한 다층 방어가 그 갭의 대부분을 메웁니다.

11 음성 안내 (Android)

벨 시점에 한국어 음성 안내를 추가하여 고령 사용자가 배너를 읽기 전에 판정을 들을 수 있도록 합니다. 기본은 비활성이며, 홈 페이지의 인트로 카드를 통해 노출되어 사용자가 갑작스러운 음성에 놀라지 않고 의식적으로 옵트인하게 합니다.

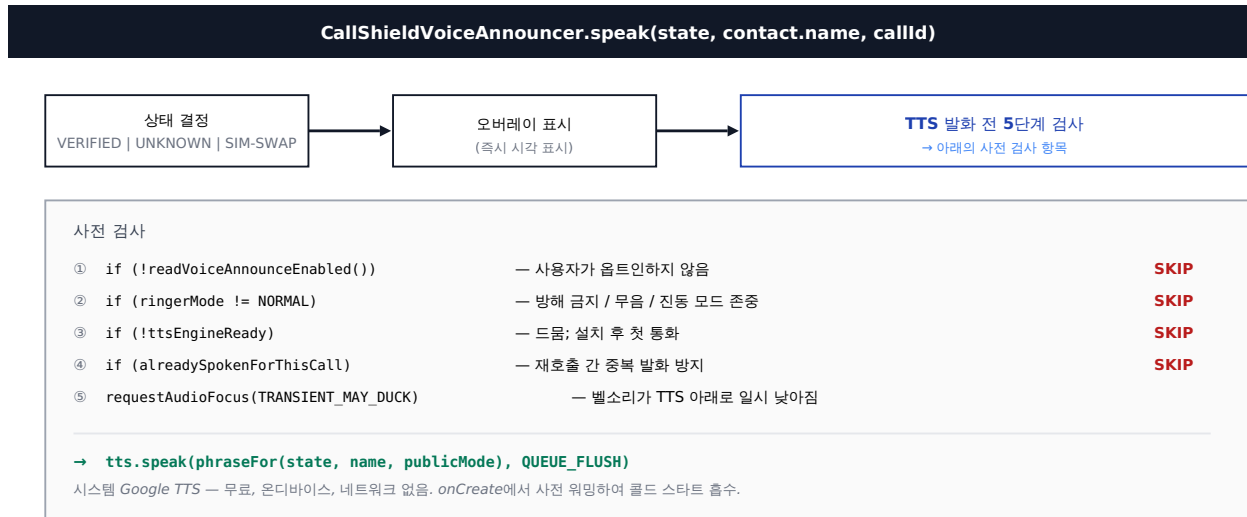


그림 11.1 — 수신 통화와 발화 사이에 다섯 개의 가드가 자리잡습니다.

음성 문구

상태	문구	비고
VERIFIED	"안전합니다. {name}에게서 온 인증된 전화입니다."	동사 우선; 음성 첫 0.5초 안에 판정
UNKNOWN	"주의하세요. {name} 번호이지만 실시간 인증이 확인되지 않았습니다."	부드러운 주의; 이름은 발화 됨
SIM-SWAP	"주의하세요. 보이스피싱 의심 전화입니다. 받지 마세요."	익명 — 이름은 발화 안 함 (스푸핑 방지)

공공장소 모드

지하철 등에서 엿들리는 것을 우려하는 사용자를 위해 토글로 녹색/노란색 문구에서 이름을 제거할 수 있습니다. SIM-swap 경로는 토글과 무관하게 항상 익명입니다. iOS는 보류 상태 — Apple이 수신 측에서 통화별 코드 실행 혹은 제공하지 않으므로 TTS를 발화할 시점이 없습니다.

12 전체 공격 시나리오

열두 가지 시나리오, 각각 실제 공격 패턴이며, 각각이 차단되는 계층에 매핑되어 있습니다. 아래 나열된 모든 방어는 2026년 5월 현재 출시 코드입니다.

#	시나리오	방어 계층	상태
A	무작위 사기꾼이 아들을 사칭하여 할머니에게 전화	CHON 페어가 없음 → 녹색 라벨이나 음성 안내 없음. 수신자는 라벨 없는 통화를 보게 되며, 라벨 없는 통화를 의심하도록 학습되어 있음.	ACTIVE
B	사기꾼이 "아들"로 가입하여 할머니에게 인증 요청	푸시가 할머니에게 전달; 요청자의 실제 계정 이름을 본 후 예를 눌러야 함. 잘못된 이름 → 아니오. Hold-to-confirm이 우발적 탭을 방지.	ACTIVE
C	사기꾼이 아들의 CHON 비밀번호를 탈취하여 Mallory의 단말로 로그인	Mallory의 단말은 자신만의 인증 키를 생성. 이전 refresh 토큰은 다음 갱신 시 DEVICE_MISMATCH 로 실패. 아들의 다른 단말로 이메일 + 푸시 알림 발송.	ACTIVE
D	C와 동일하나, Mallory가 할머니에게 전화 시도	PRECALL 신뢰 게이트가 trust_state=TRUSTED 를 요구. 새 단말은 PENDING으로 시작. PRECALL → 403. 푸시 없이 통화 도달 → Android는 빨간색 + "보이스피싱 의심" 음성.	ACTIVE
E	사기꾼이 할머니에게 가는 FCM 푸시를 가로챈	푸시 페이로드는 type과 이름만 운반. 동작은 VP API로의 JWT 인증 콜백을 요구. JWT는 할머니의 deviceId에 결속.	ACTIVE
F	시뮬레이터 / 탈옥으로 인증 위조 시도	App Attest / Play Integrity가 거부: 실제 iOS 하드웨어 AND 유효한 Apple/Google 인증서 체인 필수. 어떤 소프트웨어도 이를 위조할 수 없음.	ACTIVE
G	사기꾼이 오래된 인증 푸시 재전송	인증은 5분 안에 만료. respond의 원자적 UPDATE가 재확인 방지. 모든 상태 전이를 감사 로그에 기록.	ACTIVE
H	SIM-swap: 공격자가 손자의 번호를 가졌으나 칩은 없음	SIM은 가졌지만 칩이 없음. PRECALL 서명 불가. 셀룰러 통화가 하드웨어 검증된 푸시 없이 도달 → Android는 빨간색 + 경고 발화. 이름은 발화 안 함 (스푸핑 방지).	ACTIVE
I	분실 단말 → 사용자가 설정에서 신고	이전 단말이 REVOKED로 전환. 신뢰 게이트가 해당 단말의 PRECALL이나 LIVENESS 발화를 거부. 단말을 가진 공격자도 녹색을 띄울 수 없음.	ACTIVE
J	iPhone 발신자가 시스템 다이얼러로 Android 할머니에게 전화	LIVENESS_UPDATE 팬아웃이 Android 수신자의 캐시를 신선하게 유지. 통화별 PRECALL이 발화하지 않아도 (Apple 제약) 인증된 녹색 표시.	ACTIVE
K	인증된 통화가 부재중으로 끝남 (응답 없음)	PRECALL 후 40초가 지나면 서버가 CHON 브랜드 부재중 푸시 발송. 탭하면 해당 연락처의 call-shield 페이지로 이동.	ACTIVE

#	시나리오	방어 계층	상태
L	iPhone 발신자(시스템 다이얼러) → Android 부재중	TelephonyCallback을 통한 네이티브 부재중 감지: RINGING → IDLE without OFFHOOK + 인증된 연락처 무장 → CHON 브랜드 로컬 알림 발화.	ACTIVE

13 저장 데이터

2026년 5월 기준 데이터 현황을, 위치와 용도별로 정리했습니다.

위치	테이블 또는 저장소	주요 필드	용도
폰 — 보안 저장소			
Keychain / Keystore	kLoginModel	accessToken, refreshToken, userName, phone	세션 부트스트랩
Secure element App Attest / StrongBox	하드웨어 결속 키	비공개 키 (외부로 나가지 않음) + keyId	실제 단말 증명
EncryptedSharedPrefs (Android) / AppGroup UserDefaults (iOS)	precall_cache	{ callerPhone : expiresAtMs }	통화별 신선도
동일	liveness_cache	{ callerPhone : expiresAtMs }	대비책 활성화도
동일	voice_announce_*	enabled, public_mode	TTS 환경설정
메인 백엔드 — CHONDB (벤더 MARIADB)			
chondb	users	id, phone, hashed password, email	신원
chondb	refresh_tokens	userId, tokenJti, familyId, deviceId , expiresAt	세션 + 단말 잠금
chondb	relation_users	cert_owner_id, cert_related_id, cert_related_phone	가족 트리
chondb	auth_events	userId, event, ip, ua, ts	감사 + 새 단말 트리거
VP API — CHON_DEV / CHON_STG (RDS MARIADB · 저장 시 암호화)			
chon_dev	vp_device_token	userId, platform, fcmToken, deviceId	푸시 대상
chon_dev	vp_device_attestation	userId, keyId, public key, platform, last_heartbeat_at, trust_state	하드웨어 결속 단말 증명
chon_dev	vp_verification	id, requester_id, target_phone, target_user_id, status, expires_at	페어링

위치	테이블 또는 저장소	주요 필드	용도
chon_dev	vp_audit_log	verification_id, action, actor_user_id, ts	행위 기록
chon_dev	vp_org_directory	phone, org_name, org_type	알려진 사업자 번호

핵심 불변

비공개 하드웨어 키는 결코 네트워크를 건너지 않습니다. 서버는 공개 키(인증 시 단 1회)와 서명(하트비트 / PRECALL / 재 인증 챌린지마다)만 보냅니다. 다른 모든 상태는 복구 가능하지만 — 칩은 그렇지 않습니다.

14 현황 요약

오늘 실재하는 것, 대기 중인 것, 의도적으로 만들지 않은 것. 아래 모든 행은 dev 와 stg 브랜치 코드베이스에 반영되어 있습니다.

구성 요소	상태
하드웨어 및 인증	
하드웨어 결속 단말 키 (App Attest / StrongBox)	ACTIVE
첫 로그인 인증	ACTIVE
4시간 하트비트	ACTIVE
trust_state 컬럼 (TRUSTED/PENDING/REVOKED) + 흐름	ACTIVE
세션 및 단말 잠금	
refresh 시 device-mismatch 세션 폐기	ACTIVE
새 단말 로그인 이메일 + 두 개의 CTA 푸시	ACTIVE
페어링 (상호인증)	
요청 / 응답 / 결과 UI + hold-to-confirm	ACTIVE
5분 TTL + 원자적 응답 + 감사 로그	ACTIVE
다축 레이트 리미터	ACTIVE
verify 시 24시간 단말 쿨다운 게이트	ACTIVE
전화번호 변경 무효화 혹	ACTIVE
가족 트리 U 이전 CONFIRMED 관계 게이트	ACTIVE
통화 시점 방어	
FCM 푸시 전달 + 만료 토큰 정리	ACTIVE
CONFIRMED 후 Call Shield 연락처 동기화	ACTIVE
수신 통화 시 네이티브 통화 라벨링 (CallDirectory + screening)	ACTIVE · 양쪽 모두

구성 요소	상태
PRECALL 하드웨어 서명 게이트	ACTIVE
LIVENESS_UPDATE 팬아웃 (TRUSTED 전용, 가족 U CONFIRMED)	ACTIVE
PRECALL 윈도우용 iOS Live Activity (Pro 모델)	ACTIVE
서버 스케줄 40초 부재중 후속 푸시	ACTIVE
Android 네이티브 부재중 감지 (TelephonyCallback)	ACTIVE
TTS 음성 안내 (Android)	ACTIVE · 옵트인
음성 안내 홈 페이지 인트로 카드	ACTIVE
대기 중 / 불가능	
iOS 통화 후 요약 배너	MISSING
서버 이상 탐지 (다중 통화 공격 버스트)	MISSING
PushKit-VoIP 위장을 통한 iOS 통화별 상태	NOT FEASIBLE
포그라운드에서의 iOS 통화별 TTS	DEFERRED

15 공격자에게 열려 있는 두 개의 문

CHON으로 보호된 사용자에게 보이스피싱을 성공시키려면, 공격자는 다음 **두 가지 모두**를 뚫어야 합니다.

DOOR 1

칩

피해자의 실제 단말을, 잠금 해제된 상태로, PRECALL을 발화시킬 수 있을 만큼 물리적으로 점유하거나 — 보안 요소 키를 추출해야 합니다. 후자는 2026년 시점 Secure Enclave / StrongBox에 대해 현실적인 능력이 아닙니다.

DOOR 2

페어링

수신자가 이미 신뢰하는 가짜 계정 이름으로 새 상호인증 요청을, hold-to-confirm 과 함께, 수동으로 수락하도록 설득해야 합니다. 프롬프트는 요청자의 실제 등록 이름을 보여주므로, 미스디렉션은 탐지 가능합니다.

두 문 모두 동시에 열려야 함

Door 1은 드물고 비용이 큼니다. Door 2는 탐지 가능합니다 — 페어링이 실제 계정 이름을 노출하기 때문입니다. 시스템은 이 조합의 비용을 충분히 높게 설계해, SIM-swap 기반 보이스피싱이 CHON 사용자에게는 단순히 작동하지 않도록 했습니다. SIM, 번호, 비밀번호, FCM 스트림 — 그 어느 하나도 단독으로는 충분하지 않으며, 대부분의 공격자는 두 문 중 한쪽조차 뚫을 수 있을 뿐입니다.

16 결론

보이스피싱은 수신자가 발신자 번호를 신뢰할 때 성공합니다. 발신자 번호는 위조, SIM-swap, 다크넷 마켓 임대 등 모두 가능합니다 — 전화번호 기반 방어는 본질적으로 모두 위험에 노출되어 있습니다. CHON은 위조 불가능한 두 번째 신원 신호를 더합니다: 셀룰러 벨소리가 울리기 약 3초 전, 수신자에게 전달되는 하드웨어 결속 암호 서명입니다.

서명은 동시에 네 가지에 결속됩니다

1	비밀번호 사용자의 메인 백엔드 자격	메인 백엔드 · users
2	하드웨어 키 App Attest / StrongBox	VP API · vp_device_attestation
3	상호 확인 두 명의 실제 CHON 사용자 간	VP API · vp_verification
4	TRUSTED 상태 서명 시점의	trust_state 컬럼

수신자 단말은 벨 시점에 판정을 표시합니다

● GREEN 하드웨어 검증된 페어 칩이 서명함; 페어가 유효함; 수신자는 이것이 안전하다고 안내받음. "안전합니다."	● YELLOW Pending 또는 liveness 전용 알려진 iOS 연락처지만 통화별 서명이 없음 — 부드러운 주의. "주의하세요."	● RED 알려진 페어, 칩 없음 번호는 인증된 가족 구성원과 일치하지만 PRECALL이 없음 — SIM-swap의 정확한 서명. "보이스피싱 의심"
---	---	--

칩이 병목점입니다

SIM-swap, 비밀번호 탈취, 발신자 번호 위조, FCM 가로채기 — 모두 무력화됩니다. 그 어느 것도 칩을 주지 않기 때문입니다. CHON은 번호를 신뢰하지 않습니다. CHON은 하드웨어를 신뢰합니다.

A 용어집

이 문서 전체에서 사용되는 주요 용어입니다.

PRECALL

발신자의 CHON에서 수신자의 CHON으로 보내는 하드웨어 서명된 silent 푸시. 셀룰러 벨 약 3초 전 전송됩니다. 시스템에서 가장 단단한 암호 게이트입니다.

LIVENESS_UPDATE

서버가 팬아웃하는 silent 푸시: "사용자 A가 지금 살아 있고 온라인이다"를 A의 인증된 가족에게 전송. Apple 제약으로 iOS-다이얼러 통화에서 PRECALL이 불가능할 때, 수신자가 대비책 녹색 트리거로 사용합니다. TTL 15분.

trust_state

단말별 서버 측 상태: TRUSTED (정상), PENDING (진행 중이거나 사용자 결정을 기다리는 새 단말), REVOKED (분실 폰 리셋). TRUSTED 단말만이 PRECALL이나 LIVENESS를 발화할 수 있습니다.

상호인증 (mutual auth)

두 CHON 사용자 간의 일회성 양방향 검증. `vp_verification` 에 CONFIRMED 상태로 저장됩니다. 어느 한 쪽이 폐기할 때 까지 지속됩니다.

CallDirectory (iOS)

Apple의 서드파티 발신자 ID 확장 API. 통화 화면에 정적 라벨을 추가할 수 있지만 통화별로 변경할 수는 없습니다 — 라벨은 사전 컴파일되어 벨 시점에 읽힙니다.

CallScreeningService (Android)

벨 시점에 수신 통화를 가로채기 위해 등록하는 시스템 서비스. 전체 상태 정보와 함께 `onScreenCall` 을 실행하며, 여기서 오버레이를 그리고 음성 안내를 발화합니다.

CallRedirectionService (Android)

다이얼 시점에 발신 통화를 가로채기 위해 등록하는 시스템 서비스. 사용자가 시스템 다이얼러에서 인증된 연락처에 전화를 걸 때 PRECALL을 발화시킵니다.

CXCallObserver (iOS)

수신 통화 상태 변화에 대한 수동적 관찰자. 호스트 프로세스가 살아 있을 때만 발화합니다. 중단된 앱은 콜백을 받지 못합니다. iOS 부재중 후속이 서버 스케줄 푸시로 옮겨간 이유입니다.

NSE (Notification Service Extension, iOS)

푸시 수신 시 시스템 표시 전에 자체 프로세스에서 실행됩니다. Live Activity 시작과 푸시 콘텐츠 장식에 사용됩니다.

SIM-swap

공격자가 통신사를 설득하여 피해자의 번호를 자신이 통제하는 SIM으로 이전하는 공격 부류. 모든 전화번호 기반 방어를 무력화합니다. CHON은 무력화 **되지 않습니다** — 공격자가 여전히 피해자의 칩을 가지지 못하기 때문입니다.

deviceId

물리적 단말별 안정 식별자 (iOS의 `identifierForVendor`, Android의 `Settings.Secure.ANDROID_ID`). refresh 토큰 행에 결속되어, 다른 단말이 동일한 JWT를 사용하면 다음 갱신 시 `DEVICE_MISMATCH` 가 발화됩니다.